BankID Smishing Kit — Technical Analysis

Multi-stage credential harvesting with real-time Telegram exfiltration, targeting Norwegian banking customers

0xS3J4D November 2026

Contents

1. Executive summary
2. How this investigation started
3. Background
4. Objectives
5. Scope and method
6. Technical analysis
7. Key findings
8. Impact
9. MITRE ATT&CK mapping
10. Detection and mitigation
11. Indicators of compromise
12. Limitations
13. Lessons learned
14. Recommended next steps
References
Appendix A — Changelog

Report ID	0xS3-TR-2026-01
Version	2.0 (revised edition — see changelog)
Original analysis	March 2026
Classification	TLP:CLEAR — public, sensitive indicators redacted
Category	Phishing kit analysis / threat intelligence
Target	Norwegian BankID users (geo-fenced to `countryCode: NO`)
Delivery vector	SMS phishing (smishing) with spoofed sender ID
Kit type	Server-side PHP harvester, Telegram Bot API exfiltration
Method	Static source code review — the kit was never executed

> **Disclaimer.** This report is published for education, security awareness and defensive use. It describes how an existing phishing kit works so that it can be recognised, detected and stopped; it is not a guide to building or running one. No attack was carried out, no live infrastructure or victim data was accessed, and the kit was never deployed. Credentials, tokens, IDs and handles are redacted, and domains are defanged (`example[.]com`).

1. Executive summary

A complete phishing kit impersonating **BankID**, Norway's national electronic identity, reached the author as an ordinary smishing SMS. The author recognised a lookalike domain, retrieved the kit's ZIP archive from the phishing link and analysed it statically. The kit is built to be delivered through spoofed SMS messages and walks the victim through a **five-step data collection flow** — bank, national identity number (*fødselsnummer*), phone number, one-time code (OTP) and personal password — followed by a redirect to the real `bankid.no`.

Every field is forwarded **in real time to the operator via a Telegram bot**. That makes the kit more than a credential store: an operator watching the channel can replay a fresh OTP against the real BankID service before it expires, a classic adversary-in-the-middle (AiTM) relay.

The kit defends itself with a Norway-only geo-filter, a mobile-only user-agent check, per-character DOM obfuscation against content-based detection, and `noindex` meta tags.

Bottom line for defenders

1	Real-time OTP exfiltration via Telegram	Enables live account takeover; OTP-based MFA alone does not stop it
2	Collects the *fødselsnummer*	Permanent identifier — cannot be rotated after compromise
3	Geo- and device-fencing	Sandboxes and scanners outside Norway / on desktop see only a redirect
4	DOM text obfuscation	Breaks naive text-signature detection of phishing pages
5	Hardcoded secrets in `config.php`	High-value indicators for takedown and hunting

2. How this investigation started

The author received the SMS as a potential victim. It was not a planted sample:

1. **The message looked genuine.** Because the sender name was spoofed, the SMS landed in the same thread as earlier, legitimate messages from BankID. Nothing about the sender looked wrong.
2. **The link did not.** On a closer look, the domain read `bankld` — with a lowercase **L** in place of the **i** — a homoglyph that is almost invisible on a phone screen.
3. **Verification.** When the author typed the domain with a real `i`, it led nowhere — the genuine BankID site does not live at that address. That confirmed the link was a lookalike (typosquatting) domain, not BankID.
4. **Collection.** Instead of entering any data, the author tried to save a copy of the page for analysis. The link returned a ZIP archive containing the complete kit (PHP, HTML, JavaScript and CSS), which became the subject of this report.

No personal data was entered on the page at any point. The full domain is withheld in this public version.

Lesson: sender ID cannot be trusted, and even a familiar thread proves nothing. The one thing the attacker could not fake was the domain — and one letter gave it away.

3. Background

3.1 Why BankID is a high-value target

BankID is used by almost every Norwegian adult to log in to banks, the Tax Administration (Skatteetaten), health portals and many other services. A stolen BankID session is therefore not limited

to a single account — it can open the door to several banks and public services at once.

3.2 Delivery: smishing with spoofed sender ID

The delivery vector is confirmed first-hand (section 2). It also matches the kit's design (mobile-only, Norwegian geo-fence, BankID branding) and campaigns publicly documented by NRK, Telenor, DNB and the Norwegian Police [1–7].

With sender ID spoofing, the SMS appears to come from "BankID", "DNB" or another trusted name and can land **inside an existing legitimate message thread** on the victim's phone, which makes it very hard to tell apart from real messages [5][6].

> **Key fact:** BankID states that it never sends SMS messages containing links. Any SMS that claims to come from BankID and contains a link is fraudulent [3].

3.3 Typical lures

Representative lure themes from public reporting (not taken from the kit):

Theme	Example (Norwegian)	Psychological lever
Account suspended	"BankID: Din BankID er midlertidig sperret. Gjenopprett nå: [link]"	Urgency, fear of lock-out
Suspicious activity	"Det er oppdaget mistenkelig aktivitet på din konto. Bekreft her: [link]"	Fear of unauthorised access
Migration	"BankID Mobil skal avvikles. Oppdater nå for å beholde tilgang: [link]"	Abuses real service changes
Tax season	"Skatteetaten: Skatteoppgjøret ditt er klart. Se beregningen: [link]"	Seasonal trust
Bank login	"DNB: Uvanlig innlogging registrert. Bekreft din identitet: [link]"	Bank impersonation + urgency

When BankID on mobile (SIM-based) was being phased out in 2023, fraudsters used the migration itself as a pretext [3][7].

3.4 Scale

DNB's Financial Cyber Crime Center reported fraud attempts against the bank and its customers totalling around NOK 1.8 billion in 2023 [5], and Norwegian reporting for 2024 described record victim numbers for BankID-related fraud [8].

4. Objectives

1. Map the full victim flow and every data field collected.
2. Identify the exfiltration mechanism and extract indicators of compromise (IOCs).
3. Document evasion and anti-analysis techniques.
4. Assess impact on victims and the Norwegian identity ecosystem.

5. Map behaviour to MITRE ATT&CK and produce detection content defenders can use.

5. Scope and method

5.1 Scope

The archive contained 29 files. The functionally relevant files are:

File	Role
`index.php`	Step 1 — bank selection
`11siffer.php`	Step 2 — national identity number (11 digits)
`telefonnummer.php`	Step 3 — phone number
`6siffer.php`	Step 4 — one-time code (6 digits)
`Personlig-passord.php`	Step 5 — personal password
`success.php`	Final redirect to the real `bankid.no`
`action.php`	Backend: receives POST data and forwards it to Telegram
`config.php`	Hardcoded Telegram bot token and chat ID
`block.php`	Geo-IP filtering (Norway only)
`files/`	Cloned BankID CSS, SVG logos, favicon and spinner (remaining files)

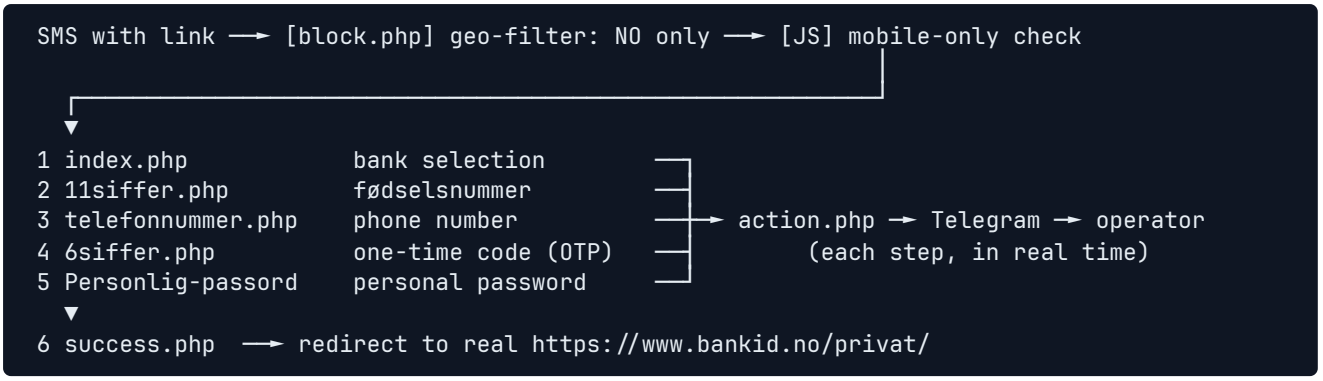
5.2 Method

Phase	Activity
Collection	Spotted the `bankld` lookalike domain in a received SMS and retrieved the kit's ZIP archive from the link instead of entering data.
Triage	Extracted the archive and reviewed the file list. Norwegian file names (`siffer`, `telefonnummer`, `passord`) and the `config.php` + `action.php` pair indicated a Telegram-exfil harvester.
Flow mapping	Read each page in sequence and traced jQuery AJAX calls and `location.href` redirects to rebuild the victim journey.
Backend analysis	Mapped every POST handler in `action.php` (`bankselect`, `11siffer`, `telefonnummer`, `6siffer`, `personligpassord`, `card`) to its Telegram API call.
Evasion analysis	Reviewed `block.php` and the client-side JavaScript on each page.
IOC extraction	Collected hardcoded infrastructure values, redirect domains and asset fingerprints.
Context	Corroborated delivery and impact against public Norwegian sources.

All work was static. Live interaction with the operator's infrastructure (for example using the extracted bot token) was deliberately **out of scope**: it would mean using criminal credentials without authorisation and could alert the operator or destroy evidence.

6. Technical analysis

6.1 Victim flow



Step	Page	Data	Sent to Telegram
1	`index.php`	Bank (dropdown with 40+ Norwegian banks)	Bank + IP + session ID
2	`11siffer.php`	National identity number	ID number + IP + session ID
3	`telefonnummer.php`	Mobile number	Phone + IP + session ID
4	`6siffer.php`	6-digit OTP	OTP + IP + session ID
5	`Personlig-passord.php`	Personal password	Password + IP + session ID
6	`success.php`	—	—

Each step posts to `action.php` via AJAX before moving on, so **a victim who quits halfway has still leaked everything entered so far**.

6.2 Geo-filtering (`block.php`)

The kit queries the commercial `pro.ip-api.com` service with a hardcoded API key. Only Norwegian IPs pass; everything else is redirected to an unrelated domain. `localhost` is whitelisted so the operator can test locally.

```
// block.php — simplified, key redacted
$ip_infos = file_get_contents('https://pro.ip-api.com/php/' . $ip . '?key=
<REDACTED>&fields=countryCode');
if (in_array($ip_infos['countryCode'], ['NO'])) {
    $_SESSION['user_allowed'] = true;
} else {
    header('Location: http://scampage[.]net/');
    exit();
}
```

This both narrows the victim pool and hides the kit from researchers, scanners and sandboxes that do not exit from a Norwegian IP.

6.3 Mobile-only enforcement

Every page hides its body until a user-agent check passes. Desktop visitors are sent away before anything renders.

```
var isMobile = /iPhone|iPad|iPod|Android/i.test(navigator.userAgent);
if (!isMobile) { window.location.href = 'https://scampages[.]net'; }
else           { document.body.style.display = 'block'; }
```

This fits the smishing vector: the victim taps the link on the same phone that received the SMS.

6.4 Real-time exfiltration via Telegram

`action.php` sends each submission to the Telegram Bot API using the token and chat ID in `config.php`. Message format (values redacted):

```
+----/!\----<.![+] Bankid 11-siffer [+]!.>---/!\----+
[11-siffer] : <national identity number>
[ID]        : <session timestamp>
[IP]        : http://geoiptool[.]com/en/?ip=<victim IP>
+----Contact Me IF YOU NEED HELP : @[REDACTED] \----+>
```

- The **session ID** (a Unix timestamp) lets the operator stitch fragments from one victim together.
- The **"Contact me"** footer with a Telegram handle is typical of kits that are sold or shared; the handle may belong to the developer rather than the person running the campaign.
- Using Telegram means no custom C2 server is needed, and traffic goes to a widely used, legitimate service that is hard to block.

AiTM implication. Because data arrives within seconds, an operator can use the victim's ID number, OTP and password to log in to the real service while the OTP is still valid. Telenor describes this real-time pattern in Norwegian fraud cases [6]. This kit contains no explicit relay automation; the relay would be performed manually by the operator.

Dormant card handler. `action.php` also contains a `card` handler (card number, expiry, CVV) with no matching front-end page, suggesting a shared code base across a wider kit family.

6.5 Fake loading screen

After each step an animated BankID spinner is shown for eight seconds before the next form appears, imitating the wait the victim expects from the real service.

```
setTimeout(function () {
    document.getElementById('wait').style.display = 'none';
    document.getElementById('getNnin').style.display = 'block';
}, 8000);
```

6.6 DOM obfuscation

On load, all visible text is rewritten so that every character is wrapped in its own `<font>` or custom `<az>` element, and random class names are added to elements:

```
const modifiedText = [...text].map(letter => `<font>${letter}</font>`).join('');
element.classList.add(`class-${rndLetter}${rndNum}-class-${rndLetter1}${rndNum1}`);
```

The victim sees normal text, but a scanner reading the DOM will not find strings like `BankID` or `Fødselsnummer` as contiguous text, and class-based fingerprints change on every load. The pattern itself — hundreds of single-character elements — is however a strong detection signal (see section 10).

6.7 Search engine suppression

All pages carry `<meta name="robots" content="noindex, nofollow">`, keeping the phishing URLs out of search results and crawler-driven discovery.

6.8 Post-harvest redirect

`success.php` sends the victim to the real `https://www.bankid.no/privat/`. Ending on the genuine site removes the most obvious cue that something went wrong and delays reporting.

7. Key findings

1. **Confirmed first-hand smishing delivery** — the author received the SMS in an existing BankID thread; the link used the homoglyph domain `bankld`.
2. **Purpose-built for smishing** — mobile-only enforcement, Norwegian geo-fence and BankID branding all point to SMS delivery.
3. **Five-step harvesting flow** collecting bank, *fødselsnummer*, phone number, OTP and password.
4. **Real-time Telegram exfiltration** per field, enabling live OTP relay (AiTM).
5. **Hardcoded bot token, chat ID and operator handle** in `config.php` / message templates — actionable IOCs.
6. **Layered evasion**: geo-filter, user-agent filter, per-character DOM obfuscation, random class names, `noindex`.
7. **High-fidelity brand cloning**: original BankID CSS, SVG logos, favicon and spinner.
8. **Dormant card-harvesting handler**, indicating a reusable kit family.
9. **Trust-preserving exit** via redirect to the real `bankid.no`.

8. Impact

Data	Consequence
Fødselsnummer	Permanent identifier used across banking, health and government. Cannot be changed; enables long-term identity fraud.
One-time code	Can be relayed to the real service within its validity window, giving the attacker an authenticated session.
Personal password	Second BankID factor; together with the above enables login.
Phone number	Enables follow-up vishing (“this is your bank’s fraud team…”) and further smishing.
Victim IP	Lets the operator mimic the victim’s region if the bank checks location.

Because BankID is accepted by a large number of Norwegian service providers, one successful session can affect several banks and public services at the same time. The redirect to the real site means many victims will not notice until money is gone.

9. MITRE ATT&CK mapping

Mapped against ATT&CK Enterprise (and Mobile for the SMS vector). Revised in v2.0 — see changelog.

Tactic	ID	Technique	Observed behaviour
Resource Development	T1583.001	Acquire Infrastructure: Domains	Lookalike domain `bankld` (homoglyph l/i)
Resource Development	T1583.006	Acquire Infrastructure: Web Services	Telegram bot used as the exfiltration endpoint
Resource Development	T1608.005	Stage Capabilities: Link Target	PHP kit hosted as the target of the SMS link
Reconnaissance	T1598.003	Phishing for Information: Spearphishing Link	Link leads to multi-step data collection
Initial Access	T1566.002	Phishing: Spearphishing Link	Link delivered by spoofed SMS
Initial Access (Mobile)	T1660	Phishing	SMS as the delivery channel
Defense Evasion	T1656	Impersonation	Cloned BankID branding, loading screen and flow
Defense Evasion	T1480	Execution Guardrails	Content only served to Norwegian IPs on mobile user agents
Defense Evasion	T1027	Obfuscated Files or Information	Per-character DOM wrapping and random class names
Credential Access / Collection	T1056.003	Input Capture: Web Portal Capture	Fake forms capture all fields
Credential Access	T1111	Multi-Factor Authentication Interception	Live capture of the BankID one-time code
Exfiltration	T1567	Exfiltration Over Web Service	Each field sent to the Telegram Bot API
Impact	T1657	Financial Theft	Intended end goal: account takeover and transfers

10. Detection and mitigation

10.1 For SOC / detection engineers

- **Kit-on-disk / hosting provider:** use the YARA rule in `detection/bankid_kit.yar` to scan web roots and kit archives. It combines the Norwegian step file names with Telegram and ip-api references.
- **Rendered-page heuristics:** flag pages where a high share of text nodes are single characters inside `<font>` / `<az>` elements, combined with BankID brand assets on a non-BankID domain.

- **Passive fingerprinting:** the cloned stylesheet `authorization.feb520e19d2d6db01d95.css` and favicon hash can be searched in urlscan.io or similar sandboxes to find sister deployments.
- **Proxy / DNS:** outbound calls from web servers to `api.telegram.org` combined with `pro.ip-api.com` are unusual for legitimate small sites.
- **Scanning tip:** analyse suspected URLs from a Norwegian exit IP with a mobile user agent — otherwise the kit only shows a redirect.

10.2 For banks and BankID

- Monitor new domains and certificates containing *bankid*, bank names or Norwegian terms (`passord`, `siffer`).
- Treat logins where the device, IP or timing differs from the session that started the flow as high risk.
- Continue moving users toward app-based, phishing-resistant authentication (BankID app with biometrics) over code generators.

10.3 For end users

- Read the domain letter by letter: `bankld` is not `bankid`. A familiar sender name or thread proves nothing.
- BankID **never** sends SMS with links. Do not click — delete the message.
- Never give your one-time code or password to anyone, on any page you reached from a link.
- If you entered data: call your bank's emergency number immediately, then report to the police.

11. Indicators of compromise

Values are redacted for public release; see `iocs/`.

Type	Indicator	Status
Telegram bot token	`[REDACTED]`	Redacted
Telegram chat ID	`[REDACTED]`	Redacted
Operator handle	`@[REDACTED]`	Redacted
Phishing domain (lookalike)	`bankld[.][REDACTED]`	Partially redacted
Geo-IP API key (ip-api.com)	`[REDACTED]`	Redacted
Redirect domain (non-NO)	`scampage[.]net`	Public
Redirect domain (desktop)	`scampages[.]net`	Public
Geo lookup in message	`geoiptool[.]com`	Public (legitimate service, abused)
Cloned asset	`authorization.feb520e19d2d6db01d95.css`	Public
File names	`11siffer.php`, `6siffer.php`, `telefonnummer.php`, `Personlig-passord.php`	Public

Note: the redirect domains are where the kit sends unwanted visitors; they are not confirmed to be operator-owned.

12. Limitations

- Static analysis only; runtime behaviour such as server-side logging could not be confirmed.
- Hosting provider and the wider campaign (other recipients, other domains) are unknown.
- The status of the bot token was **not** tested, by design. It may have been revoked.
- The operator handle is a lead, not attribution: it may belong to the developer, a reseller or a customer.
- The card handler's front end is absent from this variant; other variants may include it.

13. Lessons learned

Technical

- Telegram gives criminals free, encrypted, real-time C2 with no infrastructure to burn — expect it in most modern kits.
- Multi-step harvesting is worse than single-page theft: each partial submission has value, and the stepwise flow builds trust.
- Text-matching on the DOM is not enough; structural signals (character-wrapping, cloned assets) are more robust.
- Kit authors routinely hardcode secrets, which gives defenders strong pivots.

Operational

- Geo- and device-fenced kits require analysis infrastructure that looks like the victim (Norwegian IP, mobile UA).
- The redirect to the real site is an underrated part of the attack — it buys the operator time.

14. Recommended next steps

1. Report the bot token and handle to Telegram abuse, and share the full IOC set with **NorCERT / NSM**, **Nordic Financial CERT** and the impersonated brand through their established channels.
2. Submit domains to URLhaus / PhishTank and share the YARA rule with hosting providers.
3. Hunt for sister deployments using the cloned CSS and favicon hashes.
4. Turn the DOM-obfuscation pattern into a browser-extension or secure-web-gateway heuristic.
5. If authorised, perform dynamic analysis in an isolated sandbox with a Norwegian exit IP and a mobile UA — without submitting real data and without contacting the operator's Telegram bot.

References

1. TV 2 — "Ny svindelmetode oppdaget i Norge". https://www.tv2.no
2. NRK — "Advarer mot ny BankID-svindel: Ikke følg SMS-lenker". https://www.nrk.no
3. BankID — "Rådene som beskytter deg mot BankID-svindel". https://www.bankid.no/privat/sikkerhet/
4. Nordea — "Svindel: råd og ulike former for svindel". https://www.nordea.no
5. DNB / svindel.no — "Se opp for SMS-svindel". https://www.dnb.no/svindel
6. Telenor — "Slik prøver svindlerne å lure deg i sanntid". https://www.telenor.no
7. Politiet — "Beskytt deg mot svindel og ID-tyveri". https://www.politiet.no
8. Skimsafe — "BankID-svindel øker". https://www.skimsafe.no

9. Criipto — “How BankID Secure Start helps prevent phishing attacks”. https://www.criipto.com
10. MITRE ATT&CK. https://attack.mitre.org

Appendix A — Changelog

Version	Date	Changes
1.0	March 2026	First edition (retired).
2.0	November 2026	Restructured with executive summary and detection section; Norwegian edition added. **ATT&CK corrections:** T1566.001 → T1566.002 (link, not attachment); T1041 → T1567 (Telegram is a web service); removed T1078 and T1036.005 (not observed / wrong fit); added T1111, T1480, T1656, T1583.006, T1608.005, T1657 and Mobile T1660. Consistent “five-step” wording. Removed the claim that the bot token was “live” (not tested in a static analysis) and replaced the recommendation to query the operator’s bot with reporting through proper channels. Added YARA rule, flow diagram and source URLs. Added the first-hand account of how the SMS was received and the lookalike domain discovered (section 2), plus T1583.001.